



Siber Güvenlik ve Etik Hacking

Giriş
(SD0141)

Murat KARA

2020



1. Hafta

TANIŞMA TEMEL TERİM VE KAVRAMLAR

Merhaba

- | | |
|---------------------------|---------------------------|
| Kimim? | • Murat KARA |
| Neden bu ders? | • Farkındalık için, |
| Ne işe yarar? | • Sanal dünyada güvenlik, |
| Farkındalık gerekli mi? | • Bilgi ve Eğitim şart.. |
| ‘Hacker mı olucaz’? | • Öğreneceğiz.. Belki.. |
| Saldırı yapacak mıyız? | • Sadece Lab. Ortamına.. |
| Teknoloji ve Terminoloji? | • Pek çok.. |

<http://www.SiberGuvencik.xyz/ders>

İçerik (Hafta/Konu)

1. Tanışma, Temel Terim ve Kavramlar, Güvenliğe Giriş
2. Bilgi Güvenliği Nedir? Siber Güvenlik Nedir? Hacker Kimdir? Hacking Nedir?
3. İşletim Sistemleri ve Linux (Kali Linux)
4. Bilgisayar Ağları(Network) ve Sunucu Sistemleri
5. Kriptoloji ve Şifreleme
6. Adli Bilişim (Forensic)
7. Sanal Siber Güvenlik Ortamı Laboratuvar ve Kurulumları
8. Ara Sınav (Vize)
9. Siber Saldırı Yöntemleri – Bilgi Toplama Araçları
10. Tarama, Zafiyet Tespiti ve Parola Kırma Araçları
11. Web Güvenliği Saldırı ve Savunma Yöntem-Araçları (Temiz Kod)
12. Kablosuz Ağ Güvenliği (Saldırı-Savunma)
13. Sızma Testleri(Pentest)-Etik Hacking ve Siber Güvenlik Standartları
14. Siber Güvenliğin Hukuki Boyutu ve Bilişim Hukuku
15. Genel Tekrar ve Finale Hazırlık

Yasal Uyarı !

Türk Ceza Kanunu, Onuncu Bölüm, Bilişim Alanında Suçlar Kısımında;

Madde 243 ve Madde 244 de açıkça belirtildiği gibi;

- Bilişim sistemine girme (243)
- Sistemi engelleme, bozma, verileri yok etme veya değiştirme (244)
- **SUÇ**tur ve cezası vardır.
- İki yıldan altı yıla kadar hapis ve beşbin güne kadar adlî para cezasına hükmolunur.

Uyarı ! TCK 243

Türk Ceza Kanunu **Madde 243** (*Bilişim sistemine girme*)

- (1) Bir bilişim sisteminin bütününe veya bir kısmına, hukuka aykırı olarak giren ve orada kalmaya devam eden kimseye bir yıla kadar hapis veya adlî para cezası verilir.
- (2) Yukarıdaki fıkrada tanımlanan fiillerin bedeli karşılığı yararlanılabilen sistemler hakkında işlenmesi hâlinde, verilecek ceza yarı oranına kadar indirilir.
- (3) Bu fiil nedeniyle sistemin içerdiği veriler yok olur veya değişirse, altı aydan iki yıla kadar hapis cezasına hükmolunur.

Uyarı ! TCK 244

Türk Ceza Kanunu **Madde 244** *(Sistemi engelleme, bozma, verileri yok etme veya değiştirme)*

- (1) Bir bilişim sisteminin işleyişini engelleyen veya bozan kişi, bir yıldan beş yıla kadar hapis cezası ile cezalandırılır.
- (2) Bir bilişim sistemindeki verileri bozan, yok eden, değiştiren veya erişilmez kılan, sisteme veri yerleştiren, var olan verileri başka bir yere gönderen kişi, altı aydan üç yıla kadar hapis cezası ile cezalandırılır.
- (3) Bu fiillerin bir banka veya kredi kurumuna ya da bir kamu kurum veya kuruluşuna ait bilişim sistemi üzerinde işlenmesi halinde, verilecek ceza yarı oranında artırılır.
- (4) Yukarıdaki fıkralarda tanımlanan fiillerin işlenmesi suretiyle kişinin kendisinin veya başkasının yararına haksız bir çıkar sağlamasının başka bir suç oluşturmaması hâlinde, iki yıldan altı yıla kadar hapis ve beşbin güne kadar adlî para cezasına hükmolunur.

Temel Terimler ve Bazı Kavramlar

- Bilgi
- Güvenlik
- Bilgi Güvenliği
- Siber
- Siber Güvenlik
- Etik
- Hack
- Hacker
- Hacking
- Etik Hacker
- Etik Hacking
- Saldırı
- Savunma
- Zafiyet
- Tehdit
- Kriptoloji
- Şifre
- Adli Bilişim
- Network
- Server
- Linux
- Kali Linux
- Pentest
- Metasploitable
- Exploit
- Payload
- Owasp
- CIA
- CEH
- IDS/IPS
- SIEM
- CVE
- OSINT
- IoT
- SQLI
- Malware
- DoS/DdoS
- Metasploit

Temel Terim ve Kavramlar

- **Bilgi:** Verilerin anlam kazanmış halidir.
- **Güvenlik:** Toplumsal yaşamda düzenin aksamadan yürütülmesi.
- **Bilgi Güvenliği:** Bilginin korunması, bütünlüğü ve erişilebilir olmasını sağlayan önlemler.

Temel Terim ve Kavramlar

- **Siber:** *Cyber* kelimesinden uyarlanmış, İnternet ve bilgisayar ağlarının tamamını kapsayan sanal ortam.
- **Siber Güvenlik:** Sanal ortamda bulunan bilginin korunması ile ilgili bileşen/teknolojiler bütünüdür.
- **Etik:** Ahlâk ile ilgili (meslek ahlakı), karakter/kültür olarak doğru tutum ve davranış

Temel Terim ve Kavramlar

- **Hack:** Bir sistemin işleyiş kurallarının dışına çıkabilmektir. (Bir açıklığı kullanmak)
- **Hacker:** Bilişim alanında üst düzey bilgisi ile yazılım geliştiren/kullanan ve aradığı bilgiye erişen kişidir. (Tdk: Siber korsan)
- **Hacking:** Bir sistemin, açıklarından faydalanıp izinsiz erişim veya sistemi ele geçirmek (Programı değiştirmek)

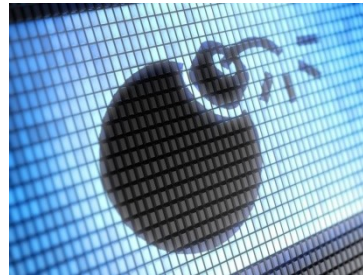


Temel Terim ve Kavramlar

- **Etik Hacker:** Bilgi ve yeteneğini etik kurallar çerçevesinde kullanan (hacker) kişilerdir. (Ahlâklı korsan)
 - Zayıflığı tespit eden, güvenlik açığını kapatmaya yardımcı olan kişidir.
- **Etik Hacking:** Sistemin açık ve tehlikeli yönlerini ortaya çıkarmak için yapılan erişim veya ele geçirme işlemi. (Sızma Testi)

Temel Terim ve Kavramlar

- **Saldırı:** Saldırganların (Devlet, kurum, şahıs, terörist, vb.) amaçları için uyguladıkları (siber) faaliyetlerdir.
- **Savunma:** Bilişim sistemlerini siber tehditlere karşı korumak için alınan önlemlerdir.



Temel Terim ve Kavramlar

- **Tehdit:** Bir sistem veya kuruluştaki zarara neden olabilecek istenmeyen bir olayın potansiyel nedeni.
- **Zafiyet:** (Vulnerability): Saldırgana fırsat verebilecek, yazılım, donanım ve prosedürler (açıklık-güvenlik boşluğu)

Temel Terim ve Kavramlar

- **Şifre:** Gizliliği olan şeylerin açılması, kullanılması veya iletilmesi için gerekli olan işaretler (harf, rakam, sembol, vb.) bütünüdür.
deneme => **8F10D078B2799206CFE914B32CC6A5E9** (md5)
- **Parola:** Gizlilik ortamında tanıma veya iletişim için gerekli anahtar (kelime) ifadedir. (Gizli)
pArola123

Temel Terim ve Kavramlar

- **Kriptoloji:** Şifre Bilimidir. Belge veya mesajın şifrelenip iletilmesi ardından deşifre edilmesini gerçekleştirmek. (İletişimde gizlilik bilimi)
(Kriptografi-Kriptoanaliz)
- **Adli Bilişim** (Forensic): Bilişim sistemleri üzerinden elde edilen nesnelerinin (yazı, resim, program vb.) mahkemede sunulmak üzere (delillerin) toplanması, saklanması, derlenmesi, analizi ile ilgili standartların ve işlemlerin bütünüdür.

Temel Terim ve Kavramlar

- **Network(Ağ):** İki veya daha fazla bilgisayarın kablolu ya da kablosuz iletişim araçları üzerinden yazılım ve donanım bileşenleriyle birbirine bağlanması ile meydana getirilen sistem bütünüdür.
- **Server(Sunucu):** Bir ağ üzerinde, program veya bilgiyi, farklı kullanıcılara/sistemlere paylaştıran/dağıtan donanım veya yazılıma verilen genel isimdir.

Temel Terim ve Kavramlar

- **Linux:** Unix işletim sistemine fikirsel ve teknik anlamda atıfta bulunarak geliştirilmiş açık kaynak kodlu, özgür ve ücretsiz (destek hariç) bir işletim sistemi çekirdeğidir. (GNU-GPL) (Unix türevidir.)
- **Kali Linux:** Sızma testleri için geliştirilmiş Debian tabanlı bir linux dağıtımıdır. Backtrack 5 devamı niteliğindedir.

Temel Terim ve Kavramlar

- **Pentest:** (Penetrasyon-Sızma Testi) Belirlenen bilişim sistemlerine mümkün olabilecek her yolun denenmesi ile sızılması..
- Kurumların kendi iletişim alt yapısı, sunucu, uygulama veya sistemlerine uyguladıkları sızma testleri..
- Test sonucu tespit edilen açıklıkların raporlanması ve yöneticilere iletilmesi işlemleridir.
- **Pentester:** Sızma testi yapan uzman kişi

Temel Terim ve Kavramlar

- **Metasploitable:** Pentestler gerçekleştirmek için güvenlik açıkları hakkında bilgi sağlayan, sızma testleri amacıyla içerisinde çeşitli araçlar (exploit, payload, auxiliary, encoder) olan bir (framework yapısı) zafiyetler barındıran bilgisayar güvenlik projesidir.
- **Exploit:** Sistemler ve servisler üzerinde yer alan güvenlik açığının kullanılmasını sağlayan araçlara denilmektedir.
- **Payload:** Hedef sistem veya servis üzerinde çalıştırılması istenen kodlara denir. (*Exploit işleminin ardından*)

Temel Terim ve Kavramlar

- **Owasp: Open Web Application Security Project**
Açık web uygulama güvenliği projesi
- Güvensiz web yazılımlarının oluşturduğu problemlere karşı mücadele etmek için kurulmuş bir topluluktur.
- Top 10 list (A1 ... A10)
 - A1: Injection
 - A2: Broken Authentication and Session Management
 - A3: Cross-Site Scripting (XSS)



OWASP

Open Web Application
Security Project

Temel Terim ve Kavramlar

- **CIA**

Siber Güvenliğin temel dayanakları olarak kabul edilen Gizlilik, Bütünlük ve Kullanılabilirlik (*Confidentiality, Integrity, and Availability*) anlamına geliyor.

- **CEH**

EC-Council tarafından sunulan bir eğitim ve sertifikadır.
Certified Ethical Hacker-Sertifikalı Etik Hacker.

Temel Terim ve Kavramlar

- **IDS/IPS**

Saldırı Tespit Sistemleri ve Saldırı Önleme Sistemleridir.

Intrusion Detection Systems and Intrusion Protection Systems.

- **SIEM**

Güvenlik Bilgileri ve Etkinlik Yönetimidir. Security Information and Event Management.

Temel Terim ve Kavramlar

- **CVE**

Mitre Corporation tarafından sunulan CVE'ler, yaygın olarak bilinen yazılım ve sistem güvenlik açıkları ve zafiyetlerdir.

Common Vulnerabilities and Exposures.

- **OSINT**

Açık Kaynak İstihbaratıdır. Open-Source Intelligence

Temel Terim ve Kavramlar

- **IoT**

Nesnelerin internetidir. Internet of Things

- **SQLI**

SQL Enjeksiyonu adı verilen saldırı şeklidir. SQL Injection

- **Malware**

Zararlı yazılımlar, kötü amaçlı yazılımlardır.

Temel Terim ve Kavramlar

- **DoS/DdoS**

Servis (Hizmet) Reddi / Dağıtılmış Hizmet Reddi anlamına gelen saldırı şeklidir.

Denial of Service/Distributed Denial of Service

- **Metasploit**

Güvenlik açıkları hakkında bilgi sağlayan, sızma testleri ve IDS imza gelişmesinde yardımcı olan bir bilgisayar güvenlik projesidir.

Güvenlik

%100 Güvenlik yoktur!

- Bilgi Güvenliği
 - Siber Güvenlik
 - İnternet güvenliği
 - Ağ güvenliği
 - Bilgisayar güvenliği
 - Mobil güvenlik
 - Siber Savaş

